INFORMATION SECURITY
MANAGEMENT SYSTEM

ISO/IEC 27001:2022 Gap Assessment

Mawingu Freight & Logistics Ltd.

Engagement type	Independent-style simulated GRC and cybersecurity assessment
Assessment period	05–16 October 2026
Report date	02 November 2026
Version	1.0 — Management issue
Classification	Confidential — Fictional training / portfolio artefact
Framework	ISO/IEC 27001:2022, including Annex A control reference

Important notice
This report describes a wholly fictional company and simulated evidence, interviews, metrics, tests and findings. It is designed to resemble a professional consulting deliverable. It is not an actual audit, certification assessment, legal opinion, penetration test or assurance conclusion. No real organisation or system was examined.

Prepared for: Board Risk Committee, Chief Executive Officer and Executive Management

Prepared by: Independent GRC & Cybersecurity Advisory — simulated engagement

1. Executive summary

Mawingu Freight & Logistics Ltd. (Mawingu) is a fictional regional freight and logistics operator headquartered in Nairobi, Kenya. The simulated assessment indicates that the organisation has several foundational security practices, but they are not yet consistently governed, evidenced or measured as an integrated Information Security Management System (ISMS). The most material exposures relate to privileged access, endpoint coverage, backup resilience, vulnerability remediation and incident response readiness.

185	3	42	14
Employees	Operating depots	Fleet vehicles	Recorded findings

Overall simulated conclusion: Developing / partially implemented. Based on the limited sample described in this report, Mawingu should not represent itself as aligned or certified to ISO/IEC 27001:2022. Management should first establish ISMS governance, confirm scope and risk appetite, assign accountable control owners, and remediate the high-risk gaps.

Key assessment indicators

Indicator	Simulated result	Interpretation
Annex A controls sampled	22 of 93	Risk-based sample; not a full control-by-control certification audit.
Control design / operation	5 effective; 10 partially effective; 7 ineffective	22 controls assessed using interviews, document review and sample testing.
Findings	3 High; 7 Medium; 4 Low	14 findings; 10 require formal corrective action or risk treatment.
Endpoint protection	151 / 185 devices reporting (81.6%)	34 devices not reporting to central EDR console at snapshot date.
MFA coverage	72% of interactive user accounts	Privileged and remote access coverage is incomplete.
Critical / high vulnerabilities	17 open beyond internal target	6 critical and 11 high severity items in the simulated scan extract.
Backup recovery exercise	1 of 3 critical services restored within RTO	Restore evidence and recovery runbooks are inconsistent.

Management decisions requested: (1) appoint an executive ISMS sponsor and cross-functional steering group; (2) approve a 90-day remediation tranche for the three High findings; (3) fund endpoint, identity and backup improvements; and (4) require monthly risk and remediation reporting to the executive committee.

2. Organisation profile and assessment context

Business model. Mawingu provides domestic and cross-border road freight, warehousing, customs documentation coordination and shipment visibility services. Its operating model relies on dispatch and fleet coordination, a cloud-hosted transport management system (TMS), finance/ERP services, Microsoft 365 collaboration, mobile devices used by supervisors and drivers, and third-party clearing, tracking and maintenance providers.

Fictional operating profile

Dimension	Assumed profile
Head office	Nairobi; finance, HR, operations control, IT and management functions.
Sites	Three depots: Nairobi (primary), Mombasa and Nakuru; site connectivity via business internet and VPN.
People and assets	185 employees; 42 vehicles; 96 corporate laptops/desktops; 64 shared/mobile operational devices; 25 servers, network appliances and virtual workloads (inventory estimate).
Core systems	Cloud TMS; cloud ERP/finance; Microsoft 365; endpoint management and EDR; firewall/VPN; CCTV and physical access systems.
Data categories	Customer and consignee contact details, shipment manifests, route and cargo data, employee records, supplier contracts, invoices and customs-related documents.
Key dependencies	Cloud hosting and SaaS providers, telecoms, fuel-card provider, vehicle tracking vendor, outsourced IT support, customs/clearing partners and payment services.
Regulatory context	Kenyan operating context assumed. Legal and regulatory applicability must be confirmed by qualified counsel; this assessment does not determine compliance with any law.

2.1 Proposed ISMS scope

Proposed initial scope: information, people, processes, technology and third-party services supporting freight booking, dispatch, shipment tracking, warehousing, finance, customer service and corporate administration at Nairobi, Mombasa and Nakuru. Include cloud services and remote access where they process, store or transmit in-scope information. Exclusions should be documented with rationale and should not create artificial boundaries around dependencies that materially affect information security.

2.2 Assessment objectives

Evaluate the design and sampled operation of selected ISMS requirements and Annex A controls; identify material risks and control gaps; assess governance, risk treatment and evidence maturity; and provide a prioritised, cost-aware improvement roadmap supporting audit readiness. This is a gap assessment, not a certification audit.

3. Methodology, criteria and limitations

The simulated engagement uses a risk-based assessment approach aligned to ISO/IEC 27001:2022 clauses 4–10 and selected Annex A controls. The work programme is modelled on common consulting practices: planning and scoping, document review, stakeholder interviews, control walkthroughs, sample inspection, risk analysis, validation of factual observations and management reporting.

3.1 Simulated procedures performed

Procedure	Simulated extent / evidence
Document review	ISMS policy pack, IT acceptable-use policy, access procedure, incident procedure, backup standard, supplier register, asset inventory, risk register, BCP and change records (18 evidence items requested; 15 supplied; 3 unavailable or incomplete).
Interviews	CEO, Head of IT, IT administrator, Operations Manager, HR Manager, Finance Manager, depot supervisors and outsourced IT support (8 interview sessions).
Identity and access sampling	25 user accounts, 8 privileged accounts, 10 leaver records and 6 supplier accounts.
Endpoint / vulnerability sampling	EDR console snapshot covering 185 expected endpoints; vulnerability extract for 25 server/network assets and 40 sampled endpoints.
Backup / continuity	Backup job summaries for 30 days; restore evidence for 3 critical services; tabletop exercise record and BCP review date.
Logging / incident response	Central log-source inventory, 14-day sample of security alerts, 6 incident tickets and incident escalation procedure.
Physical / supplier	Site access records at Nairobi and Mombasa; 8 critical supplier records and 3 service agreements.

3.2 Rating model

Rating	Definition
Effective	Control is designed appropriately, assigned, operating consistently and supported by sufficient evidence in the sample.
Partially effective	Control exists but coverage, consistency, ownership, documentation or evidence is incomplete.
Ineffective	Control is absent, materially deficient, or not operating as intended in the sample.
Not assessed	Outside the agreed simulated sample; no conclusion should be inferred.

3.3 Limitations and reliance

All company facts, system names, metrics, evidence records, interview statements, test outcomes and findings are invented for demonstration. No systems were accessed and no vulnerability scans, penetration tests, forensic procedures or legal reviews were performed. The 22-control sample is not exhaustive and cannot establish conformity with all 93 Annex A controls or all ISO clauses. Results are illustrative and should not be used to make real-world investment, regulatory, contractual or certification decisions.

4. Results and maturity assessment

4.1 Control maturity snapshot

Assessment area	Maturity (1–5)	Summary
ISMS governance and leadership	2.0	Policies exist; executive oversight, measurable objectives and management review are not formalised.
Risk assessment and treatment	2.0	Risk register is incomplete; risk owners and treatment decisions are inconsistently recorded.
Asset and information management	2.5	Core asset list exists but mobile, SaaS and data-flow coverage is incomplete.
Identity and access management	2.0	Joiner/mover/leaver process exists; MFA and privileged access controls have gaps.
Operations and vulnerability management	2.0	Patching occurs but remediation SLAs, exception handling and evidence are weak.
Logging and incident response	2.0	Alerts are generated but central coverage, triage ownership and exercises are limited.
Backup and business continuity	2.0	Backups run; recovery objectives and restore testing are not consistently demonstrated.
Supplier security	2.5	Critical suppliers are known, but due diligence and ongoing assurance are inconsistent.
Awareness and competence	3.0	Induction training is delivered; role-based refreshers and phishing measurement are limited.
Physical security	3.0	Site controls generally present; visitor and access-log review evidence is uneven.

Maturity scale: 1 = ad hoc; 2 = developing; 3 = defined; 4 = managed and measured; 5 = optimised. Scores are qualitative consulting judgements for this fictional scenario, not an ISO scoring model.

4.2 Annex A sample result

Outcome	Count	Share of sample
Effective	5	22.7%
Partially effective	10	45.5%
Ineffective	7	31.8%
Total sampled	22	100%

The sample suggests that control foundations are present but inconsistent. The most important management issue is not simply the existence of policies; it is whether control owners can demonstrate that controls operate across all sites, users, systems and suppliers, and whether exceptions are tracked to closure.

5. Detailed findings and recommendations

Findings are ranked using a simulated likelihood × impact model. High findings require executive sponsorship and immediate treatment planning. Medium findings should be assigned and tracked through the ISMS corrective-action process. Low findings should be addressed through normal control improvement.

F-01 | HIGH — Privileged accounts lack consistent MFA and review

Observation: 8 privileged accounts sampled; 3 did not have MFA enforced and 5 had no documented quarterly owner review. One shared administrator credential was identified in the simulated access list.

Risk / consequence: Compromise of an administrator account could enable broad access to TMS, file repositories and infrastructure. Shared credentials reduce accountability.

Recommended action: Enforce phishing-resistant MFA where feasible for all privileged and remote access; remove shared accounts; implement named admin accounts, PAM or controlled vaulting; perform quarterly recertification; retain approvals and sign-in evidence.

Accountable owner: Head of IT **Target:** 30 days **ISO reference:** A.5.15, A.5.16, A.5.18, A.8.2

F-02 | HIGH — Endpoint detection coverage is incomplete

Observation: EDR console showed 151 of 185 expected endpoints reporting (81.6%). 34 devices were stale, missing or not enrolled; 11 were assigned to operational depots.

Risk / consequence: Unmonitored devices may permit malware or credential theft to persist without central detection, especially at remote depots.

Recommended action: Reconcile asset inventory to EDR; enrol or isolate all supported endpoints; define 95% coverage in 30 days and 98% in 60 days; alert on stale agents; report exceptions weekly.

Accountable owner: Head of IT / Depot Managers **Target:** 45 days **ISO reference:** A.8.1, A.8.7, A.8.16

F-03 | HIGH — Backup recovery capability not proven against business targets

Observation: Backups ran for core systems, but only 1 of 3 sampled critical services was restored within its stated recovery time objective. Restore test evidence was missing for TMS and finance platform.

Risk / consequence: A ransomware event, cloud outage or data corruption could cause prolonged dispatch disruption and delayed customer deliveries.

Recommended action: Approve service-level RTO/RPO; implement immutable or logically isolated backup copies; document runbooks; test full restoration quarterly and after material change; capture timed evidence and lessons learned.

Accountable owner: Head of IT / Operations Director **Target:** 60 days **ISO reference:** A.5.29, A.5.30, A.8.13

F-04 | MEDIUM — Vulnerability remediation is not governed by risk-based SLAs

Observation: The simulated scan extract contained 6 critical and 11 high vulnerabilities older than the internal 30-day target; 4 lacked a recorded remediation owner.

Risk / consequence: Known exploitable weaknesses may remain exposed and remediation cannot be reliably escalated.

Recommended action: Adopt severity- and exposure-based SLAs (e.g. critical 7 days, high 30 days); assign owners; track exceptions with expiry and compensating controls; rescan to verify closure.

Accountable owner: IT Operations Lead **Target:** 60 days **ISO reference:** A.8.8

F-05 | MEDIUM — Joiner/mover/leaver evidence is inconsistent

Observation: 2 of 10 sampled leaver records showed access removal later than the internal 24-hour target; one supplier account had no expiry date.

Risk / consequence: Former staff or suppliers may retain access to business systems and shipment/customer information.

Recommended action: Integrate HR exit notification with service desk; disable accounts within 4 hours for involuntary exits and 24 hours otherwise; require sponsor and expiry for supplier accounts; monthly exception review.

Accountable owner: HR Manager / IT **Target:** 45 days **ISO reference:** A.5.16, A.5.18

F-06 | MEDIUM — Security logging coverage and alert ownership are incomplete

Observation: TMS audit events and firewall logs were available, but VPN, selected server and endpoint events were not consistently forwarded to a central review point. Alert ownership was informal.

Risk / consequence: Threat activity may not be correlated or investigated promptly; evidence may be unavailable for incident response.

Recommended action: Define minimum log-source baseline; centralise identity, endpoint, firewall, VPN, server and critical SaaS logs; synchronise time; assign daily triage and escalation; retain logs according to risk and legal advice.

Accountable owner: Head of IT **Target:** 90 days **ISO reference:** A.8.15, A.8.16, A.8.17

F-07 | MEDIUM — Incident response plan has not been exercised

Observation: Procedure identifies escalation contacts but has no tested severity matrix, evidence-preservation checklist or documented tabletop in the previous 12 months.

Risk / consequence: A major cyber incident could lead to delayed containment, unclear decisions and poor communications.

Recommended action: Approve incident severity criteria, roles, contact tree, evidence handling and external notification decision process; conduct a ransomware tabletop within 60 days; track lessons to closure.

Accountable owner: CEO / Head of IT **Target:** 60 days **ISO reference:** A.5.24, A.5.25, A.5.26, A.5.27

F-08 | MEDIUM — ISMS risk register does not consistently link risks to owners and treatment

Observation: Risk register contains 18 entries; 7 lack named owners, 9 have no treatment decision and 6 have not been reviewed in the last 12 months.

Risk / consequence: Management cannot demonstrate a repeatable risk-based basis for control selection or residual-risk acceptance.

Recommended action: Adopt documented likelihood/impact criteria; assign business risk owners; record inherent/residual ratings, treatment, due dates and acceptance authority; review quarterly and after significant change.

Accountable owner: Risk & Compliance Lead **Target:** 60 days **ISO reference:** Clauses 6.1.2, 6.1.3

F-09 | MEDIUM — Supplier security due diligence is not consistently risk-tiered

Observation: Of 8 critical suppliers sampled, 3 had no current security questionnaire or assurance evidence and 2 contracts lacked explicit incident notification timeframes.

Risk / consequence: A supplier compromise or outage may affect shipment operations and customer information without timely notification or assurance.

Recommended action: Tier suppliers by data access and operational criticality; perform due diligence before onboarding and annually; include security, breach notification, subcontracting, audit and exit clauses.

Accountable owner: Procurement Manager / Legal **Target:** 90 days **ISO reference:** A.5.19, A.5.20, A.5.21, A.5.22

F-10 | MEDIUM — Business continuity plans lack tested dependency mapping

Observation: BCP references manual dispatch but does not identify minimum data sets, telecom dependencies, alternate site arrangements or recovery decision authority.

Risk / consequence: Operations may not recover consistently during a site, cloud or telecom outage.

Recommended action: Complete business impact analysis; approve RTO/RPO for critical processes; map people, applications, data and supplier dependencies; test alternate dispatch process twice yearly.

Accountable owner: Operations Director **Target:** 120 days **ISO reference:** A.5.29, A.5.30

F-11 | LOW — Asset inventory does not fully cover SaaS and mobile devices

Observation: Inventory omits 7 SaaS services and has incomplete assignment/location fields for 12 shared mobile devices.

Risk / consequence: Ownership, access and data-handling expectations may be unclear for less visible assets.

Recommended action: Reconcile procurement, finance and identity sources; assign business and technical owners; classify information and record SaaS/mobile assets.

Accountable owner: IT Asset Owner **Target:** 120 days **ISO reference:** A.5.9, A.5.12

F-12 | LOW — Security objectives are not measurable

Observation: Policy states general intentions but has no approved KPI baseline, target or reporting cadence.

Risk / consequence: Management may be unable to assess whether the ISMS is improving or meeting intended outcomes.

Recommended action: Approve a small KPI set: MFA, EDR coverage, patch SLA, restore success, incident triage and training completion; review monthly.

Accountable owner: ISMS Manager **Target:** 90 days **ISO reference:** Clauses 6.2, 9.1

F-13 | LOW — Awareness evidence is not role-based

Observation: Induction completion is recorded for 89% of staff; no tailored training evidence exists for privileged users, finance payment approvers or depot supervisors.

Risk / consequence: High-risk roles may not recognise targeted phishing, payment diversion or data-handling threats.

Recommended action: Complete overdue induction; deliver role-based modules and short simulations; track completion and repeat failures with coaching.

Accountable owner: HR Manager **Target:** 120 days **ISO reference:** A.6.3

F-14 | LOW — Document control and review dates are inconsistent

Observation: 3 of 12 sampled security documents had no owner or next review date; one procedure referenced an obsolete escalation contact.

Risk / consequence: Staff may follow outdated instructions and audit evidence may be difficult to retrieve.

Recommended action: Implement controlled repository, document owner, version, approval, review date and change history; review critical procedures annually and after incidents.

Accountable owner: ISMS Manager **Target:** 120 days **ISO reference:** Clause 7.5

6. Illustrative information security risk register

The following priority risks translate the control observations into business outcomes. Scores use a 5×5 model: likelihood (1–5) × impact (1–5). Inherent score is before current controls; residual score reflects the simulated current control environment. Ratings are illustrative and must be validated by accountable business owners.

Risk ID	Scenario / business impact	Inherent	Residual	Owner	Treatment
R-01	Privileged account compromise leads to TMS or infrastructure takeover; dispatch disruption and data exposure.	5×5 = 25 Critical	4×5 = 20 Critical	Head of IT	Mitigate — MFA, named admin, PAM, reviews
R-02	Ransomware spreads through unmanaged endpoints at depots; operational outage and recovery costs.	5×5 = 25 Critical	4×4 = 16 High	Head of IT	Mitigate — EDR coverage, isolation, backups
R-03	Cloud or ransomware incident exposes weak recovery capability; TMS unavailable beyond tolerable outage.	4×5 = 20 Critical	4×4 = 16 High	Operations Director	Mitigate — immutable backup, restore tests, BIA
R-04	Unpatched internet-facing or server vulnerability is exploited; unauthorised access or service interruption.	4×5 = 20 Critical	3×4 = 12 High	IT Operations Lead	Mitigate — vulnerability SLAs, verification
R-05	Former employee or supplier retains access; misuse of shipment/customer data.	4×4 = 16 High	3×4 = 12 High	HR Manager	Mitigate — timely deprovisioning, expiry
R-06	Supplier compromise or outage disrupts shipment tracking or exposes customer information.	3×5 = 15 High	3×4 = 12 High	Procurement Manager	Mitigate — tiering, due diligence, clauses
R-07	Security incident not detected or escalated promptly due to fragmented logs and unclear ownership.	4×4 = 16 High	3×4 = 12 High	Head of IT	Mitigate — central logging, triage, exercise
R-08	Fire, flood, telecom or site outage disrupts dispatch and warehouse operations.	3×5 = 15 High	3×4 = 12 High	Operations Director	Mitigate — BIA, continuity tests

6.1 Risk acceptance and escalation

No Critical residual risk should be accepted solely by the IT function. The proposed governance model requires the relevant business risk owner to recommend treatment, the executive risk committee to review material residual exposure, and the CEO or Board Risk Committee to approve acceptance above the organisation's defined tolerance. Acceptance must include rationale, compensating controls, expiry/review date and named approver.

6.2 Proposed risk appetite statements

Mawingu should target zero unapproved critical vulnerabilities on internet-facing assets; 100% MFA for privileged and remote access; at least 98% managed endpoint detection coverage; tested recovery for all critical services against approved RTO/RPO; and no overdue high-risk access recertifications. Any exception should be time-bound and formally accepted by the appropriate risk owner.

7. ISO/IEC 27001:2022 alignment and Statement of Applicability considerations

ISO/IEC 27001:2022 requires an organisation to establish, implement, maintain and continually improve an ISMS. Annex A is a reference set of controls; organisations determine necessary controls through risk treatment and compare them with Annex A when preparing the Statement of Applicability (SoA). The table below is a preliminary mapping for the fictional scenario, not a completed SoA.

ISO clause	Expected management system evidence	Simulated position / priority
4 — Context	Internal/external issues, interested parties, scope and process interfaces.	Scope is proposed; context and interested-party register not formally approved. High priority.
5 — Leadership	Leadership commitment, policy, roles, responsibilities and authorities.	Policy exists; executive sponsorship and ISMS accountability need formal approval.
6 — Planning	Risk assessment/treatment methodology, risk treatment plan, SoA and measurable objectives.	Risk register incomplete; treatment plan and SoA not yet controlled.
7 — Support	Resources, competence, awareness, communication and documented information.	Induction exists; role-based competence and document control need improvement.
8 — Operation	Operational planning, risk assessment and implementation of treatment plan.	Operational controls run inconsistently; change and supplier evidence gaps.
9 — Performance evaluation	Monitoring, measurement, internal audit and management review.	No approved KPI pack; internal audit programme and management review cadence not evidenced.
10 — Improvement	Nonconformity, corrective action and continual improvement.	Issue tracking exists informally; root-cause and effectiveness checks should be standardised.

7.1 Preliminary Annex A applicability themes

Control theme	Relevant control references (illustrative)	Preliminary treatment direction
Organisational	A.5.1–A.5.7, A.5.9, A.5.15–A.5.23, A.5.24–A.5.30	Generally applicable; formalise policies, risk, supplier, incident and continuity controls.
People	A.6.1–A.6.8	Applicable; strengthen screening where lawful, terms, awareness and remote working.
Physical	A.7.1–A.7.14	Applicable to offices, depots, equipment, visitors and secure areas.
Technological	A.8.1–A.8.34	Applicable based on TMS, endpoints, cloud, networks, development/configuration and operations.

The organisation must determine each Annex A control's applicability and justification, including controls not selected, in a formally approved SoA. The control references in findings are indicative mappings; validate exact control titles and applicability against the licensed standard before formal audit use.

8. Prioritised remediation roadmap

The roadmap sequences urgent exposure reduction before broader ISMS formalisation. Dates are relative to management approval (Day 0); owners should confirm capacity, dependencies and funding. High findings should not wait for the full ISMS build.

Wave / timing	Workstream and deliverables	Accountable lead	Exit criteria
0–30 days	Appoint sponsor and ISMS working group; approve interim risk escalation; enforce MFA for all privileged accounts; remove shared admin credential; assign all critical/high vulnerability owners; reconcile endpoint inventory.	CEO / Head of IT	Sponsor and RACI approved; privileged MFA at 100%; shared account retired; all critical/high items owned.
31–60 days	Complete EDR deployment or isolate exceptions; approve backup RTO/RPO; conduct TMS and finance restore tests; complete leaver and supplier access clean-up; run incident tabletop; approve risk methodology.	Head of IT / Operations / HR	EDR ≥95%; restore evidence for 3 critical services; tabletop actions assigned; access exceptions closed or accepted.
61–90 days	Centralise priority log sources; establish daily alert triage; approve supplier tiering and contract clauses; baseline ISMS KPIs; publish risk treatment plan and draft SoA.	ISMS Manager / Procurement	Priority log sources onboarded; monthly dashboard issued; risk treatment plan and SoA reviewed by owners.
91–180 days	Approve ISMS scope and policy suite; conduct business impact analysis; implement internal audit programme; perform internal audit; complete management review; close corrective actions.	ISMS Sponsor / Internal Audit	Documented evidence for clauses 4–10; internal audit completed; management review minutes and decisions retained.
181–270 days	Run effectiveness testing; remediate audit findings; validate supplier assurance; conduct continuity exercise; consider independent readiness review before certification body engagement.	Executive Committee	High findings closed; residual risks accepted; readiness decision supported by objective evidence.

8.1 Indicative investment bands

The following are planning bands only, not vendor quotes: (a) identity and endpoint uplift — KES 1.5m–3.5m; (b) backup resilience and recovery testing — KES 1.0m–2.5m; (c) logging/SIEM onboarding and managed monitoring — KES 2.0m–5.0m initial setup plus recurring service costs; (d) ISMS governance, training and internal audit support — KES 0.8m–2.0m. Costs depend on existing licences, architecture, data volumes, provider selection and internal capacity. Validate through procurement and a detailed design.

8.2 Proposed management dashboard

KPI	Baseline (simulated)	90-day target	Owner / cadence
Privileged MFA coverage	62.5% (5/8 sampled)	100%	IT / weekly
EDR reporting coverage	81.6% (151/185)	≥98%	IT / weekly
Critical/high vulnerabilities beyond SLA	17 open	0 critical; ≤3 high with approved exception	IT / weekly
Leaver access removed within target	80% (8/10)	≥98%	HR + IT / monthly
Critical service restore tests passed	1/3 within RTO	3/3 within approved RTO/RPO	IT + Operations / quarterly
Security awareness completion	89% induction	≥98%; 100% for high-risk roles	HR / monthly
High findings overdue	Not established	0 overdue without approved exception	ISMS Manager / monthly

9. ISMS governance and audit-readiness plan

9.1 Recommended governance structure

Role / forum	Core accountability
Board Risk Committee	Approve risk appetite; oversee critical residual risks and ISMS performance at least quarterly.
CEO / Executive Sponsor	Provide direction and resources; approve ISMS scope and policy; resolve cross-functional barriers.
ISMS Steering Group (monthly)	Coordinate risk treatment, objectives, incidents, supplier risk, metrics and corrective actions.
ISMS Manager / Risk & Compliance Lead	Maintain ISMS documentation, risk register, SoA, audit programme, KPI pack and management review inputs.
Control owners	Operate controls, retain evidence, investigate exceptions and complete corrective actions.
Internal audit (independent of control operation)	Assess conformity and effectiveness against the audit programme; report findings without owning controls.

9.2 Minimum controlled document set

Document / record	Minimum content / evidence expectation
ISMS scope and context	Approved scope boundaries, sites, services, interfaces, interested parties and exclusions rationale.
Information security policy and objectives	Management approval, communication, measurable objectives, owners and review cycle.
Risk methodology, risk register and treatment plan	Criteria, owners, inherent/residual ratings, treatment decisions, due dates and acceptance approvals.
Statement of Applicability	All Annex A controls considered; applicability, implementation status and justification for inclusion/exclusion.
Asset, information and supplier registers	Owner, classification, location, criticality, supplier tier, access and review date.
Operational procedures	Access, change, vulnerability, backup, logging, incident, continuity, supplier and physical security.
Competence and awareness records	Role requirements, training completion, exercises, acknowledgements and effectiveness evidence.
Monitoring, internal audit and management review	KPI results, audit plans/reports, nonconformities, decisions, resources and continual improvement actions.

9.3 Internal audit readiness gates

Before inviting a certification body, management should be able to demonstrate: (1) a stable, approved ISMS scope; (2) risk assessment and treatment completed for in-scope processes; (3) a complete and justified SoA; (4) operational controls running with retained evidence; (5) measurable objectives and monitoring; (6) at least one completed internal audit cycle covering the ISMS; (7) management review with documented decisions; and (8) corrective actions evaluated for effectiveness. Certification bodies determine their own audit programme and conclusions.

10. Appendix A — Interview themes and simulated evidence register

The statements below are fictional summaries used to make the case study internally consistent. They are not quotations from real employees.

Interviewee / function	Simulated theme raised	Assessment implication
CEO	Wants assurance that shipment operations can continue through a cyber incident; security ownership is largely delegated to IT.	Need executive sponsorship, risk appetite and management review.
Head of IT	Small team supports multiple depots; EDR deployment and central log integration are incomplete.	Need prioritised control ownership, capacity and service-provider oversight.
Operations Manager	Dispatch has manual workarounds, but the latest recovery exercise did not test full TMS restoration.	Need BIA, tested recovery and alternate operating procedures.
HR Manager	Leaver notifications are mostly email-based; evidence is not always attached to tickets.	Need workflow integration and measurable deprovisioning SLA.
Finance Manager	Payment approvals use email and ERP; targeted phishing is a concern.	Need role-based awareness and stronger identity controls.
Procurement Manager	Security review is performed for some technology suppliers but not consistently for all critical partners.	Need risk-tiered supplier due diligence and contract clauses.
Depot supervisors	Shared operational devices are used across shifts; device ownership and patch status are not always visible.	Need device inventory, assignment and endpoint coverage.

10.1 Evidence register (selected)

Ref	Evidence item	Simulated status	Use / limitation
E-01	Information Security Policy v1.3	Supplied	Approved 2025; review date not recorded.
E-02	IT Asset Inventory export	Supplied — partial	185 endpoint expectation reconciled against EDR; SaaS/mobile gaps remain.
E-03	EDR console device export	Supplied	151 active/reporting endpoints; snapshot only.
E-04	Privileged access listing	Supplied	8 privileged accounts sampled; MFA and review gaps identified.
E-05	Leaver tickets	Supplied — sample	10 records; 2 late access removals.
E-06	Vulnerability scan summary	Supplied	6 critical and 11 high items past internal target; scan coverage not independently validated.
E-07	Backup job reports (30 days)	Supplied	Job success does not demonstrate recoverability.
E-08	Restore test records	Supplied — incomplete	1 of 3 critical services restored within stated RTO.
E-09	Incident response procedure	Supplied	No recent tabletop evidence; contact list partially stale.
E-10	Central logging source list	Supplied — partial	Coverage gaps for VPN, selected servers and endpoint events.
E-11	Critical supplier register	Supplied	8 critical suppliers; 3 missing current security evidence.
E-12	Business continuity plan	Supplied — partial	Manual dispatch described; dependency mapping and exercise evidence incomplete.
E-13	Risk register	Supplied — partial	18 entries; ownership/treatment/review gaps.
E-14	Security awareness completion	Supplied	89% induction completion; role-based records unavailable.
E-15	Site visitor/access logs	Supplied — partial	Nairobi and Mombasa sample; review evidence inconsistent.
E-16	Change records	Not supplied	Unable to assess change approval and emergency change operation.
E-17	Internal audit programme	Not supplied	No evidence of a completed ISMS internal audit cycle.
E-18	Management review minutes	Not supplied	No formal ISMS management review evidence.

11. Appendix B — Definitions, scoring and management response

Finding. A condition identified through the simulated assessment that indicates a control weakness, evidence gap or opportunity for improvement. Findings are not formal ISO nonconformities because no certification audit has been conducted.

Risk score. Likelihood (1–5) multiplied by impact (1–5). Suggested bands: 1–4 Low; 5–9 Moderate; 10–15 High; 16–25 Critical. The severity labels applied to findings are consultant-style prioritisation and should be calibrated to an approved enterprise risk methodology.

Residual risk. Risk remaining after considering controls currently assumed to operate. Residual scores in this report are illustrative judgements and require business-owner validation.

Corrective action. An action addressing the cause of a gap, with an accountable owner, target date, evidence of completion and effectiveness review. A policy update alone is not sufficient where the underlying control is not operating.

11.1 Suggested management action tracker

Action ID	Decision / action requested	Suggested accountable role	Due
MA-01	Approve ISMS sponsor, steering group and decision rights.	CEO	Within 15 days
MA-02	Approve remediation plan and resources for F-01 to F-03.	Executive Committee	Within 30 days
MA-03	Confirm risk appetite and residual-risk acceptance authority.	Board Risk Committee	Within 45 days
MA-04	Approve ISMS scope, risk methodology and measurable objectives.	ISMS Sponsor	Within 60 days
MA-05	Commission internal audit after core controls have operated long enough to generate evidence.	Audit Committee / Internal Audit	Within 180 days
MA-06	Decide whether to proceed to independent readiness review and certification planning.	CEO / Board Risk Committee	Within 270 days

11.2 Management response

Management should record agreement, disagreement or partial agreement for each finding; identify the accountable risk owner; approve treatment, transfer, avoidance or acceptance; and provide target dates. Where management accepts risk, the rationale, approving authority, compensating controls and review/expiry date should be recorded. This report does not presume management acceptance of any risk.

End of report

Mawingu Freight & Logistics Ltd. — ISO/IEC 27001:2022 Gap Assessment | Version 1.0 | 02 November 2026

Confidential — fictional case study. All names, data, findings, interviews and results are simulated.